DOSSIER TECHNIQUE :

Mission 9 – Supervision avancée avec intégration Active Directory / LDAP

Groupe D :

Membre de groupe :

Exauce HAZOUME

MATHIEU NDJEE MINOUE

Muhammed TOURAY

Sommaire

1. Introduction et Contexte
2. Définition des mots-clés et concepts techniques
3. Étape 0 : Préparation du serveur web (Activation des modules LDAP)
4. Étape 1 : Configuration de l'authentification (Côté Linux / Apache2)
5. Étape 2 : Création des identités numériques (Côté Windows Server / AD)
6. Étape 3 : Tableau des rôles et attribution des autorisations (Côté Linux / Nagios)
7. Étape 4 : Rapport de tests des accès (Validation de la sécurité)
8. Étape 5 : Vérification de la traçabilité (Analyse des journaux)
9. Étape 6 : Procédure d'exploitation (Guide d'ajout d'un utilisateur)
10. Conclusion

1. Introduction et Contexte

Dans le monde de l'administration systèmes et réseaux, l'installation d'un outil de supervision comme Nagios n'est que la première étape d'une gestion d'infrastructure efficace. Lors de notre déploiement initial (Mission 8), nous avions réussi à rendre la supervision opérationnelle, mais nous nous heurtions à une limite technique majeure : les comptes utilisateurs et les mots de passe étaient gérés localement, directement sur le serveur Linux, via un simple fichier texte de type .htpasswd.

Pour une infrastructure de l'envergure de StadiumCompany, cette méthode s'avère rapidement obsolète et pose de lourds problèmes de sécurité et de maintenance. En effet, gérer les identités machine par machine devient impossible à grande échelle, augmente le risque d'erreurs humaines, et ne permet pas d'appliquer une politique de mots de passe unifiée.

C'est pour répondre à cette problématique que la direction nous a confié cette Mission 9. L'objectif est de professionnaliser notre outil en le connectant au cœur même du Système d'Information de l'entreprise : l'annuaire Active Directory (AD).

L'ambition de ce dossier technique est de détailler, pas à pas, la transition d'une authentification locale vers une authentification centralisée utilisant le protocole LDAP. Nous allons voir comment faire dialoguer notre serveur Linux (Apache/Nagios) avec notre serveur Windows Server. Cependant, ouvrir la porte d'entrée ne suffit pas : ce document expliquera également comment nous avons cloisonné les droits à l'intérieur de l'application en créant des profils métiers stricts (Administrateur, Technicien, Simple Lecteur) pour garantir que chaque collaborateur n'ait accès qu'aux fonctions nécessaires à son poste. Enfin, nous démontrerons comment la mise en place d'une traçabilité complète permet de garder le contrôle total sur les actions effectuées sur le réseau. Ce guide a été conçu de manière exhaustive pour permettre à quiconque de comprendre et de reproduire cette architecture complexe.

2. Définition des mots-clés et concepts techniques

Afin de bien comprendre les manipulations qui vont suivre, voici un rappel des termes techniques essentiels utilisés dans cette architecture :

- **Active Directory (AD) :** C'est l'annuaire d'entreprise hébergé sur notre serveur Windows. Il centralise toutes les identités (utilisateurs, groupes) et gère la politique de sécurité du réseau.
- **LDAP (Lightweight Directory Access Protocol) :** C'est le protocole de communication (le "langage") standardisé qui permet à notre serveur Linux d'interroger l'annuaire Active Directory pour vérifier si un utilisateur existe et si son mot de passe est correct.
- **Apache2 :** C'est le logiciel de serveur web installé sur notre machine Linux. C'est lui qui héberge l'interface graphique de Nagios et qui se charge d'afficher la fenêtre de connexion sécurisée avant de laisser passer l'utilisateur.
- **Authentification vs Autorisation :** L'authentification vérifie *qui nous sommes* (le contrôle du mot de passe à l'entrée). L'autorisation vérifie *ce que nous avons le droit de faire* une fois à l'intérieur (lire, modifier, supprimer).
- **Unité d'Organisation (OU - Organizational Unit) :** C'est un conteneur logique dans l'Active Directory (similaire à un dossier) qui permet de classer et de regrouper nos utilisateurs de manière structurée (ex: une OU "Supervision").
- **UPN (User Principal Name) :** C'est le format de connexion qui ressemble à une adresse email (ex: utilisateur@domaine.local). Il est beaucoup plus simple à configurer dans Linux que les longs chemins LDAP traditionnels.

3. Étape 0 : Préparation du serveur web (Activation des modules LDAP)

Objectif : Par défaut, notre serveur web Linux (Apache2) est incapable de comprendre le protocole LDAP. Si nous essayons de le relier à Windows immédiatement, il affichera une erreur. Nous devons d'abord activer les "traducteurs" internes d'Apache.

Procédure :

Sur le terminal de notre serveur Linux, nous saisissons les commandes suivantes avec les droits d'administration :

1. **Activation du module de communication LDAP de base :**

Bash

a2enmod ldap

2. **Activation du module d'authentification LDAP :**

(C'est ce module spécifique qui permet de confronter les mots de passe tapés sur la page web avec ceux de l'Active Directory)

Bash

a2enmod authnz_ldap

3. **Application des nouveaux paramètres :**

Nous redémarrons le service web pour qu'il charge ces nouvelles fonctionnalités en mémoire.

Bash

systemctl restart apache2

```
root@Nagios:~# a2enmod ldap authnz_ldap
Enabling module ldap.
Considering dependency ldap for authnz_ldap:
Module ldap already enabled
Enabling module authnz_ldap.
To activate the new configuration, you need to run:
  systemctl restart apache2
root@Nagios:~#
```

Remarque importante : Le terme a2enmod signifie littéralement "Apache2 Enable Module". C'est une commande indispensable avant toute intégration avec un annuaire externe.

4. Étape 1 : Configuration de l'authentification (Côté Linux / Apache2)

Objectif : Modifier le fichier de configuration du site web Nagios pour lui ordonner de rejeter les anciens mots de passe locaux et d'exiger une validation auprès de notre serveur Windows (172.20.1.2).

Procédure :

1. Nous ouvrons le fichier de configuration avec l'éditeur de texte nano :

Bash

```
nano /etc/apache2/sites-enabled/nagios.conf
```

2. Dans ce fichier, nous localisons les blocs **<Directory "/usr/local/nagios/sbin">** et **<Directory "/usr/local/nagios/share">.**
3. Nous désactivons l'ancienne méthode locale en plaçant des symboles dièse (#) devant les lignes **AuthUserFile.** C'est ce qu'on appelle "commenter" le code.
4. Nous insérons ensuite notre nouveau bloc de configuration LDAP :

Apache

```
AuthName "Acces Supervision StadiumCompany"

AuthType Basic

AuthBasicProvider ldap

AuthLDAPURL
"ldap://172.20.1.2:389/DC=stadiumcompany,DC=local?sAMAccountName?sub?(objectClass=
user)"

AuthLDAPBindDN "srv-ldap@stadiumcompany.local"

AuthLDAPBindPassword "Bts2026"

Require valid-user
```

```
  GNU nano 8.4
      <RequireAll>
         Require all granted
#        Require host 127.0.0.1

         AuthName "Nagios Access"
         AuthType Basic
         AuthUserFile /usr/local/nagios/etc/htpasswd.users
         Require valid-user
      </RequireAll>
   </IfVersion>
   <IfVersion < 2.3>
      Order allow,deny
      Allow from all
#     Order deny,allow
#     Deny from all
#     Allow from 127.0.0.1

      AuthName "Nagios Access"
      AuthType Basic
      AuthUserFile /usr/local/nagios/etc/htpasswd.users
      Require valid-user
   </IfVersion>
</Directory>

Alias /nagios "/usr/local/nagios/share"

<Directory "/usr/local/nagios/share">
#  SSLRequireSSL
   Options None
   AllowOverride None
   <IfVersion >= 2.3>
      <RequireAll>
         Require all granted
#        Require host 127.0.0.1

         AuthName "Nagios Access"
         AuthType Basic
         AuthUserFile /usr/local/nagios/etc/htpasswd.users
         Require valid-user
      </RequireAll>
   </IfVersion>
   <IfVersion < 2.3>
      Order allow,deny
      Allow from all
#     Order deny,allow
#     Deny from all
#     Allow from 127.0.0.1

      AuthName "Nagios Access"
      AuthType Basic
      AuthUserFile /usr/local/nagios/etc/htpasswd.users
      Require valid-user
   </IfVersion>
</Directory>
```

```
ScriptAlias /nagios/cgi-bin "/usr/local/nagios/sbin"

<Directory "/usr/local/nagios/sbin">
#  SSLRequireSSL
   Options ExecCGI
   AllowOverride None
   <IfVersion >= 2.3>
      <RequireAll>
         #Require all granted
#        Require host 127.0.0.1

         #AuthName "Nagios Access"
         #AuthType Basic
         #AuthUserFile /usr/local/nagios/etc/htpasswd.users
         #Require valid-user

         AuthName "Acces Supervision StadiumCompany"
         AuthType Basic
         AuthBasicProvider ldap
         AuthLDAPURL "ldap://172.20.1.2:389/DC=stadiumcompany,DC=local?sAMAccountName?sub?(objectClass=user)"
         AuthLDAPBindDN "srv-ldap@stadiumcompany.local"
         AuthLDAPBindPassword "Bts2026"
         Require valid-user
      </RequireAll>
   </IfVersion>
   <IfVersion < 2.3>
      Order allow,deny
      Allow from all
#     Order deny,allow
#     Deny from all
#     Allow from 127.0.0.1

      #AuthName "Nagios Access"
      #AuthType Basic
      #AuthUserFile /usr/local/nagios/etc/htpasswd.users
      #Require valid-user
   </IfVersion>
</Directory>

Alias /nagios "/usr/local/nagios/share"

<Directory "/usr/local/nagios/share">
#  SSLRequireSSL
   Options None
   AllowOverride None
   <IfVersion >= 2.3>
      <RequireAll>
         #Require all granted
#        Require host 127.0.0.1

         #AuthName "Nagios Access"
         #AuthType Basic
         #AuthUserFile /usr/local/nagios/etc/htpasswd.users
         #Require valid-user
                                                                    [ Lecture de 77 lignes ]
^G Aide        ^O Écrire      ^F Chercher    ^K Couper      ^T Exécuter    ^C Emplacement  M-U Annuler     M-A Marquer
^X Quitter     ^R Lire fich.  ^\ Remplacer   ^U Coller      ^J Justifier   ^/ Aller ligne   M-E Refaire     M-6 Copier
```

```
  GNU nano 8.4                                                    /etc/apache2/sites-enabled/nagios.conf
      </RequireAll>
   </IfVersion>
   <IfVersion < 2.3>
      Order allow,deny
      Allow from all
#     Order deny,allow
#     Deny from all
#     Allow from 127.0.0.1

      #AuthName "Nagios Access"
      #AuthType Basic
      #AuthUserFile /usr/local/nagios/etc/htpasswd.users
      #Require valid-user
   </IfVersion>
</Directory>

Alias /nagios "/usr/local/nagios/share"

<Directory "/usr/local/nagios/share">
#  SSLRequireSSL
   Options None
   AllowOverride None
   <IfVersion >= 2.3>
      <RequireAll>
         #Require all granted
#        Require host 127.0.0.1

         #AuthName "Nagios Access"
         #AuthType Basic
         #AuthUserFile /usr/local/nagios/etc/htpasswd.users
         #Require valid-user

         AuthName "Acces Supervision StadiumCompany"
         AuthType Basic
         AuthBasicProvider ldap
         AuthLDAPURL "ldap://172.20.1.2:389/DC=stadiumcompany,DC=local?sAMAccountName?sub?(objectClass=user)"
         AuthLDAPBindDN "srv-ldap@stadiumcompany.local"
         AuthLDAPBindPassword "Bts2026"
         Require valid-user
      </RequireAll>
   </IfVersion>
   <IfVersion < 2.3>
      Order allow,deny
      Allow from all
#     Order deny,allow
#     Deny from all
#     Allow from 127.0.0.1

      #AuthName "Nagios Access"
      #AuthType Basic
      #AuthUserFile /usr/local/nagios/etc/htpasswd.users
      #Require valid-user
   </IfVersion>
</Directory>
```

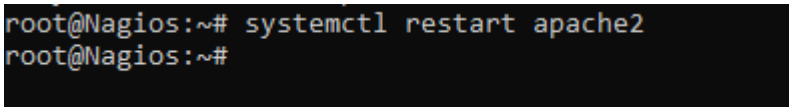
Explication détaillée des directives utilisées pour la compréhension de l'équipe :

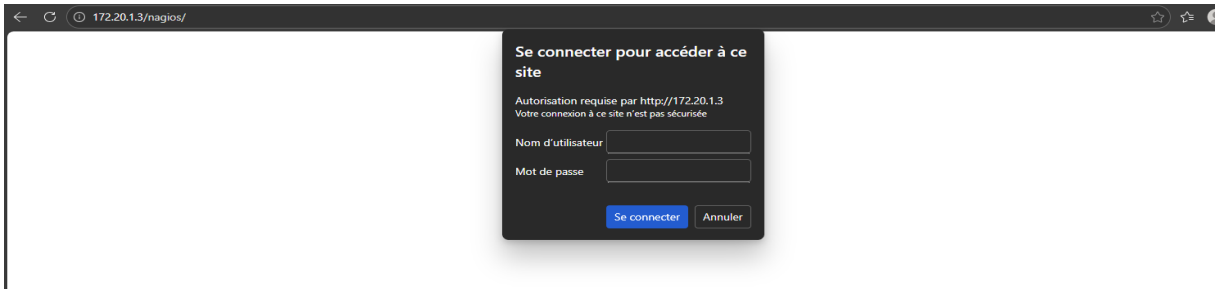
- AuthName : Le message personnalisé qui s'affichera sur la fenêtre de connexion des utilisateurs.
- AuthLDAPURL : L'adresse IP de notre serveur Windows (172.20.1.2), le port standard LDAP (389), et notre nom de domaine (stadiumcompany.local).
- AuthLDAPBindDN et AuthLDAPBindPassword : C'est le "compte de service" (notre vigile virtuel). Apache utilise le compte srv-ldap avec le mot de passe Bts2026 pour avoir le droit de fouiller dans l'annuaire Windows et vérifier les identifiants des autres employés.
- Require valid-user : Bloque l'accès à toute personne ne possédant pas un compte reconnu.

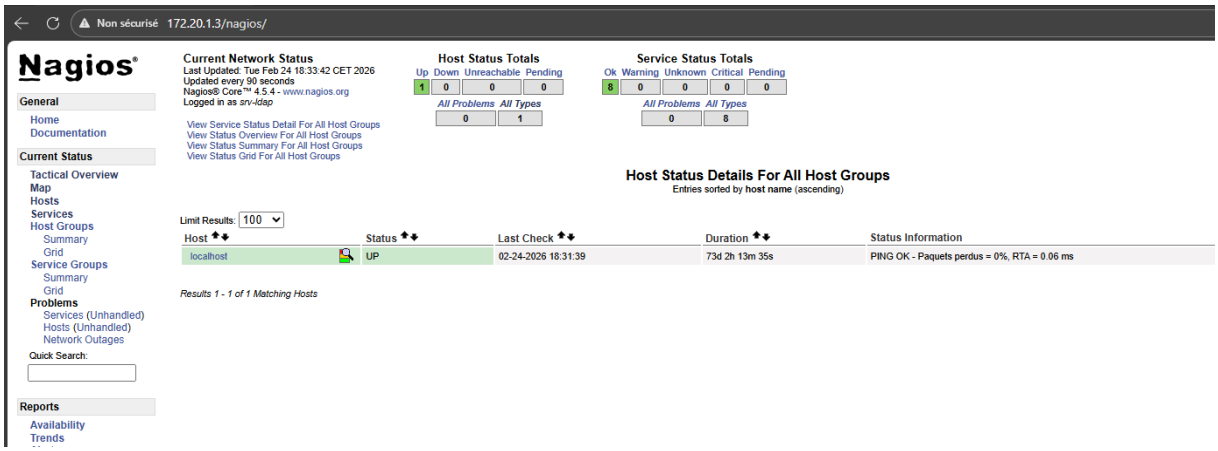
5. Nous sauvegardons le fichier (**Ctrl+O**, puis **Entrée**) et nous le fermons (**Ctrl+X**).
6. Nous redémarrons le serveur Apache pour appliquer cette nouvelle politique de sécurité :

Bash

systemctl restart apache2







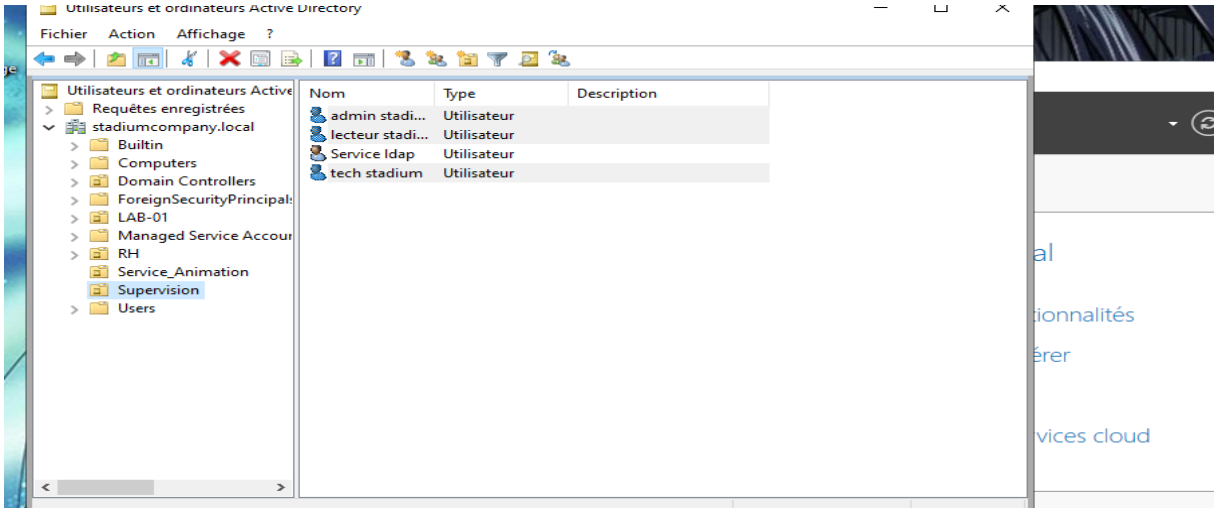
***Légende** : Le serveur web exige désormais une authentification Active Directory via la fenêtre pop-up sécurisée.*

5. Étape 2 : Création des identités numériques (Côté Windows Server / AD)

Objectif : Créer physiquement les comptes utilisateurs dans notre infrastructure Windows pour qu'ils soient reconnus lors de la tentative de connexion sur la page web.

Procédure :

1. Sur le contrôleur de domaine Windows Server, nous utilisons le raccourci clavier **Windows + R** et saisissons la commande dsa.msc. Cela ouvre instantanément la console "Utilisateurs et ordinateurs Active Directory" (très utile pour contourner les éventuels bugs d'affichage du Gestionnaire de serveur).
2. Nous faisons un clic droit sur notre nom de domaine (stadiumcompany.local) pour créer une nouvelle **Unité d'Organisation (OU)** que nous nommons **Supervision**.
3. À l'intérieur de cette OU, nous créons nos comptes de test via *Clic droit > Nouveau > Utilisateur*.
4. Il est crucial de bien définir le Nom d'ouverture de session de l'utilisateur car c'est cet identifiant exact que Nagios cherchera. Nous avons créé trois profils distincts :
    - Administrateur : admin-stadium
    - Technicien : tech-stadium
    - Lecteur : lecteur-stadium
5. Nous attribuons un mot de passe robuste à chacun et cochons l'option "Le mot de passe n'expire jamais" pour faciliter nos tests en laboratoire.



***Légende** : Centralisation des identités dans l'Unité d'Organisation dédiée à la supervision.*

6. Étape 3 : Tableau des rôles et attribution des autorisations (Côté Linux / Nagios)

Objectif : L'authentification (l'entrée) fonctionne, mais par sécurité, Nagios bloque l'affichage interne par défaut. Nous devons maintenant configurer l'Autorisation (le contrôle d'accès basé sur les rôles) en modifiant le fichier de contrôle CGI.

Tableau d'affectation des rôles :

Profil Métier	Compte AD associé	Droits accordés sur la plateforme Nagios
Administrateur	admin-stadium	**Contrôle total.** Lecture globale, gestion complète des alertes, et modification des paramètres système du moteur Nagios.
Technicien	tech-stadium	**Exploitation.** Lecture de tous les équipements et services. Autorisation d'interagir avec les alertes (acquittement, désactivation des notifications). Pas d'accès au système central.
Simple Lecteur	lecteur-stadium	**Consultation.** Affichage de l'état du réseau (tableaux de bord, cartographie). Interdiction stricte d'exécuter la moindre commande d'action.

Procédure technique d'attribution :

1. Nous éditons le fichier des permissions Nagios :

Bash

nano /usr/local/nagios/etc/cgi.cfg

2. Nous ajoutons les identifiants de nos utilisateurs (séparés par des virgules et sans espaces) à la fin des variables de configuration correspondantes :

    - **Pour le droit de Consultation universelle (Les 3 profils) :**

Plaintext

authorized_for_all_services=nagiosadmin,admin-stadium,tech-stadium,lecteur-stadium

authorized_for_all_hosts=nagiosadmin,admin-stadium,tech-stadium,lecteur-stadium

```
authorized_for_all_services=nagiosadmin,srv-ldap,admin-stadium,tech-stadium,lecteur-stadium
authorized_for_all_hosts=nagiosadmin,srv-ldap,admin-stadium,tech-stadium,lecteur-stadium
```

- **Pour le droit d'Intervention sur les alertes (Admin et Tech uniquement) :**

Plaintext

authorized_for_all_service_commands=nagiosadmin,admin-stadium,tech-stadium

authorized_for_all_host_commands=nagiosadmin,admin-stadium,tech-stadium

```
authorized_for_all_service_commands=nagiosadmin,admin-stadium,tech-tadium
authorized_for_all_host_commands=nagiosadmin,admin-stadium,tech-stadium
```

- **Pour le droit de Gestion du Système (Admin uniquement) :**

Plaintext

authorized_for_system_information=nagiosadmin,admin-stadium

authorized_for_configuration_information=nagiosadmin,admin-stadium

authorized_for_system_commands=nagiosadmin,admin-stadium

```
authorized_for_system_information=nagiosadmin,admin-stadium



# CONFIGURATION INFORMATION ACCESS
# This option is a comma-delimited list of all usernames that
# can view ALL configuration information (hosts, commands, etc).
# By default, users can only view configuration information
# for the hosts and services they are contacts for. You may use
# an asterisk (*) to authorize any user who has authenticated
# to the web server.

authorized_for_configuration_information=nagiosadmin,admin-stadium



# SYSTEM/PROCESS COMMAND ACCESS
# This option is a comma-delimited list of all usernames that
# can issue shutdown and restart commands to Nagios via the
# command CGI (cmd.cgi).  Users in this list can also change
# the program mode to active or standby. By default, *no one*
# has access to this unless you choose to not use authorization.
# You may use an asterisk (*) to authorize any user who has
# authenticated to the web server.

authorized_for_system_commands=nagiosadmin,admin-stadium
```

3. Nous redémarrons le moteur principal de Nagios pour injecter ces règles de sécurité :

Bash

systemctl restart nagios

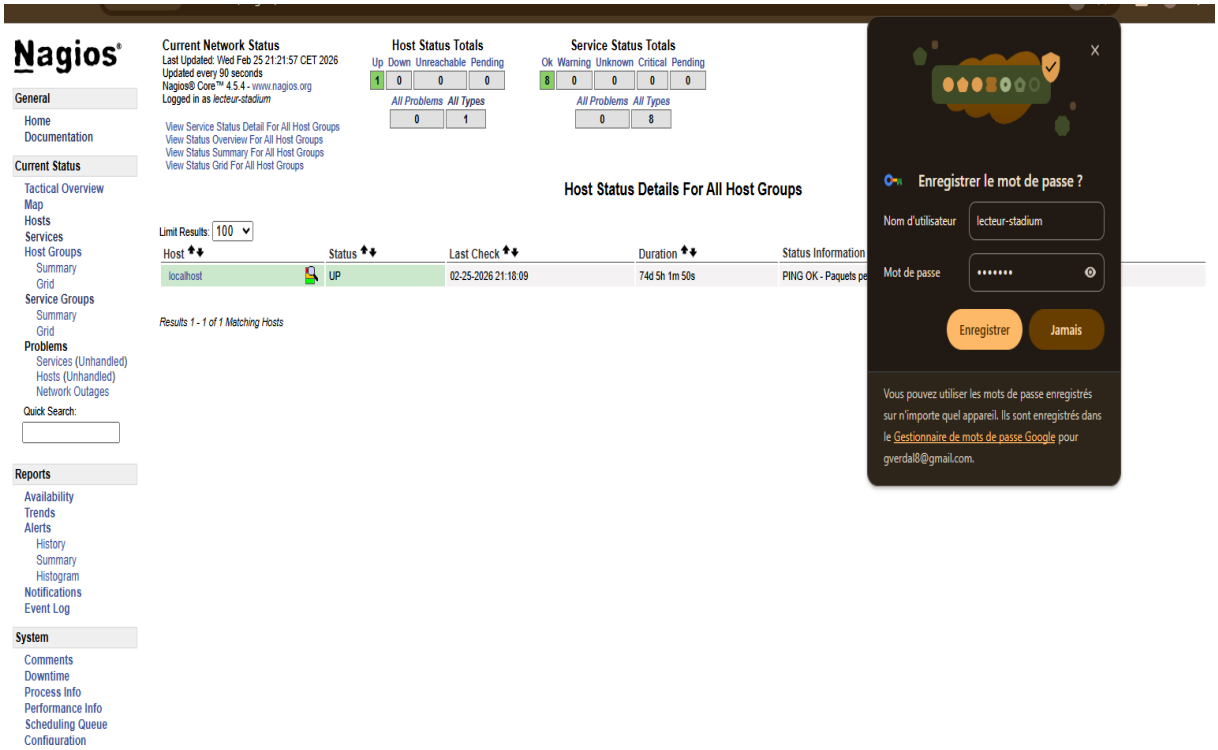
```
root@Nagios:~# nano /usr/local/nagios/etc/cgi.cfg
root@Nagios:~# systemctl restart apache2
root@Nagios:~#
```

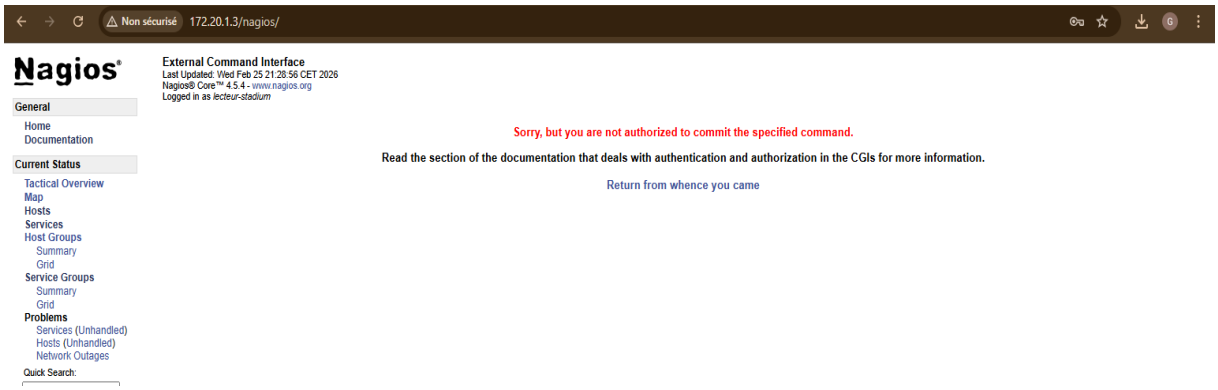
7. Étape 4 : Rapport de tests des accès (Validation de la sécurité)

Pour valider l'étanchéité de notre système de permissions (Livrable 4), nous avons procédé à des tests d'intrusion fonctionnels. La méthode consiste à se connecter avec un profil restreint et à tenter d'exécuter une action privilégiée.

Test de restriction (Profil Simple Lecteur) :

- **Méthodologie :** Connexion à l'interface web avec les identifiants de lecteur-stadium. Navigation vers les détails de l'équipement "localhost". Tentative de clic sur l'action critique *"Disable notifications for this host"*, puis validation en cliquant sur *"Commit"*.
- **Résultat obtenu :** Échec de la commande. La plateforme bloque immédiatement l'action et renvoie un message d'erreur d'autorisation rouge : *"Sorry, but you are not authorized to commit the specified command."*
- **Conclusion :** Le verrouillage des actions non autorisées est validé.

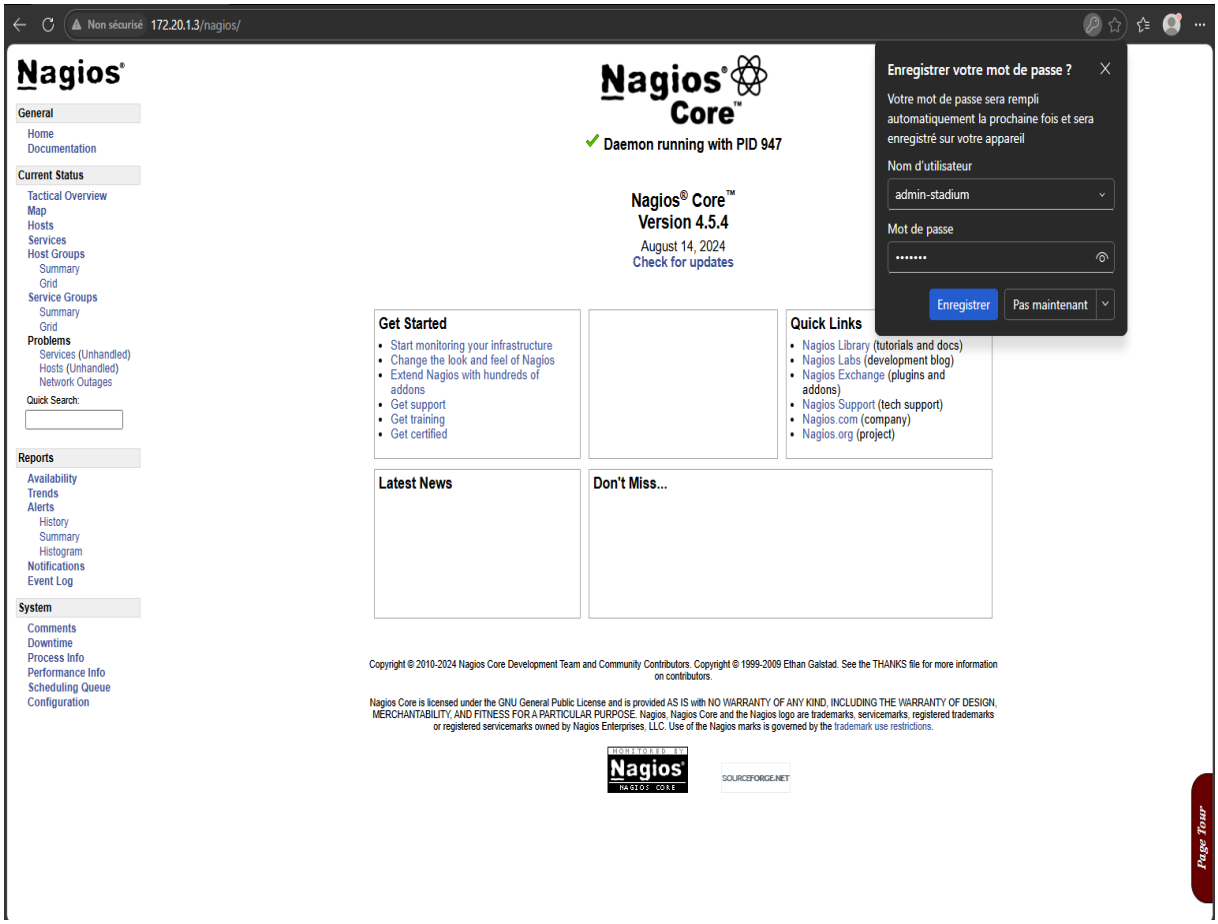


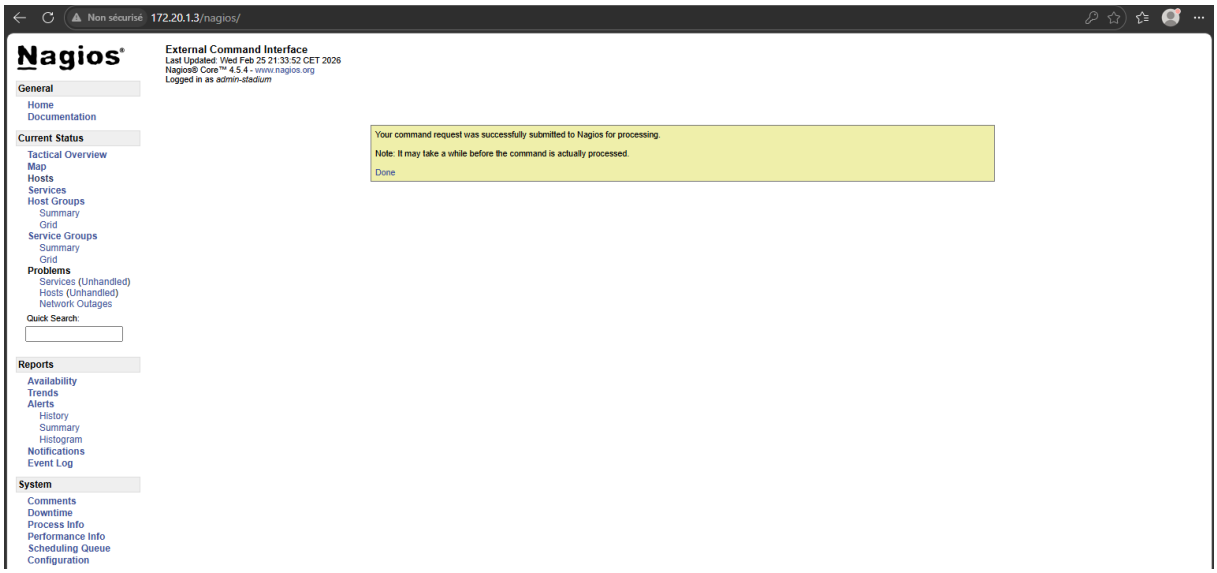


Légende *: Blocage effectif d'une commande non autorisée pour le profil Lecteur.*

Test d'élévation de privilèges (Profil Administrateur) :

- **Méthodologie :** Déconnexion du navigateur, puis reconnexion en tant que admin-stadium. Exécution de la même action critique sur l'équipement "localhost" (*"Disable notifications"*).
- **Résultat obtenu :** Succès de la commande. L'interface renvoie un message de confirmation jaune : *"Your command request was successfully submitted to Nagios for processing."*
- **Conclusion :** Les droits étendus de l'administrateur sont reconnus et opérationnels.





Légende *: Validation et prise en compte de l'action privilégiée pour l'Administrateur.*

8. Étape 5 : Vérification de la traçabilité (Analyse des journaux)

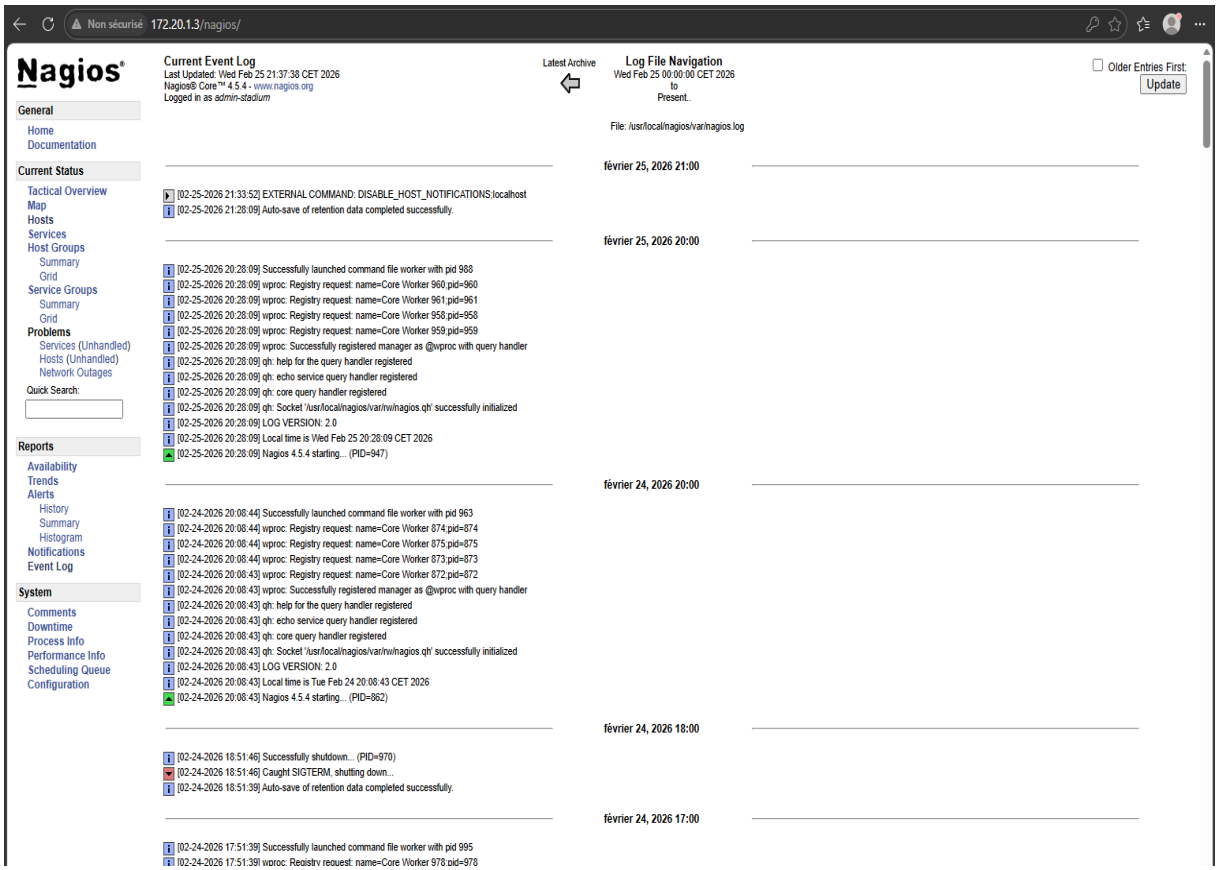
Objectif : Répondre à l'exigence de la direction d'assurer une traçabilité complète (auditabilité) des actions opérées sur le réseau.

Procédure et Résultat :

1. Connectés avec notre profil administrateur, nous naviguons dans le menu latéral gauche, sous la rubrique Reports, et sélectionnons Event Log.
2. La consultation de ces journaux système montre clairement l'historique chronologique. Nous pouvons y lire l'action de désactivation de notification effectuée lors de notre test précédent :

[Date et Heure] EXTERNAL COMMAND: DISABLE_HOST_NOTIFICATIONS;localhost

3. Ce fichier journal prouve que chaque commande externe envoyée par un collaborateur est horodatée et archivée, permettant ainsi de retrouver la source d'une modification en cas de dysfonctionnement ou d'audit de sécurité.



Légende *: Extrait de l'Event Log confirmant la traçabilité des opérations de supervision.*

9. Étape 6 : Procédure d'exploitation (Guide d'ajout d'un utilisateur)

Ce mode opératoire simplifié est destiné au service de support informatique de StadiumCompany afin d'assurer la maintenance courante de la plateforme.

Comment attribuer l'accès à Nagios à un nouveau collaborateur ?

Prérequis : Les mots de passe ne sont plus créés sur le serveur Linux. Toute l'identité numérique est gérée depuis le serveur Windows.

1. **Phase 1 : Création de l'identité (Contrôleur de domaine Windows)**
    - Se connecter au serveur Active Directory.
    - Ouvrir la console dsa.msc et se rendre dans l'Unité d'Organisation Supervision.
    - Créer le compte utilisateur, définir son mot de passe, et noter précisément son Nom d'ouverture de session (exemple : j.dupont).
2. **Phase 2 : Paramétrage des autorisations (Serveur de supervision Linux)**
    - Se connecter au terminal Linux et éditer le fichier des rôles :

nano /usr/local/nagios/etc/cgi.cfg

- Ajouter l'identifiant (ex: j.dupont) à la fin des directives correspondant à son métier, en séparant toujours par une virgule :
    - *Pour un Lecteur :* Ajouter l'ID uniquement sur les lignes authorized_for_all_services et _hosts.
    - *Pour un Technicien :* Ajouter l'ID en plus sur les lignes authorized_for_all_service_commands et _host_commands.
    - *Pour un Administrateur :* Ajouter l'ID sur toutes les lignes, y compris celles se terminant par _system_information, _configuration_information et _system_commands.
- Sauvegarder et fermer l'éditeur de texte.

3. **Phase 3 : Déploiement**
    - Relancer le service pour acter les modifications :

```
systemctl restart nagios
```

- Le collaborateur peut instantanément se connecter à l'interface graphique.

10. Conclusion

La Mission 9 de l'entreprise StadiumCompany est finalisée avec succès. Nous avons fait évoluer l'outil Nagios d'une configuration locale basique à une intégration professionnelle complète au sein du Système d'Information de l'entreprise.

La liaison avec l'annuaire Active Directory LDAP garantit une gestion des mots de passe centralisée et sécurisée. La mise en place rigoureuse des autorisations dans le fichier de configuration assure un cloisonnement total des fonctions entre les administrateurs, les techniciens d'exploitation et les simples lecteurs. Enfin, la traçabilité exhaustive offerte par les journaux d'événements répond parfaitement aux exigences d'audit de la direction. Ce socle technique est désormais robuste, documenté et prêt à être exploité en condition réelle.